

GOVERN.AI

The Sovereign Control Plane for Enterprise AI

TECHNICAL OVERVIEW

Versione: MVP 3.0

Data: 14 Maggio 2026

Autore: ANTHERA Systems

Classificazione: Confidential

Indice

- 1. Executive Summary
- 2. Architettura del Sistema
- 3. Modello Dati (7 Collections)
- 4. Flussi Applicativi
- 5. Sistema di Sicurezza
- 6. Moduli Funzionali
- 7. Compliance Framework
- 8. Deployment & DevOps
- 9. Roadmap Prodotto
- 10. Target Audience & Value Proposition

1. Executive Summary

GOVERN.AI è una piattaforma software (SaaS) progettata per **governare, monitorare e garantire la compliance** degli agenti AI nelle organizzazioni enterprise. Si posiziona come il **control plane** tra gli agenti AI aziendali e le normative europee, garantendo che ogni azione sia tracciata, conforme e auditabile.

Il Problema

- **Mancanza di visibilità:** Le organizzazioni non sanno cosa fanno i loro agenti AI
- **Rischio normativo:** EU AI Act, GDPR, DORA, NIS2 richiedono tracciabilità completa
- **Assenza di controllo:** Nessun meccanismo per definire policy di governance degli agenti
- **Audit impossibile:** Nessun log strutturato per dimostrare conformità ai regolatori

La Soluzione

- **Registro centralizzato** di tutti gli agenti AI con profilo di rischio completo
- **Motore di policy** con rilevamento automatico conflitti per 8 normative
- **SOX Section 404 Wizard** con Audit Readiness Score per controlli interni
- **Audit trail completo** di ogni azione, con export PDF/CSV per i regolatori
- **Dashboard di compliance** con monitoraggio real-time di 8 standard
- **Assistente AI (ARIA)** esperto di regolamentazione, con SSE streaming

2. Architettura del Sistema

L'architettura segue un pattern a due tier (Frontend SPA + Backend API) con database document-oriented e integrazione LLM esterna. L'intero stack è containerizzato con Docker Compose.

2.1 Stack Frontend

Componente	Tecnologia	Scopo
Framework	React 19	UI reattiva e componentizzata
Styling	Tailwind CSS 3.4	Design system utility-first
Components	Shadcn/UI + Radix	Componenti accessibili e consistenti
Charts	Recharts	Visualizzazioni dati interattive
Routing	React Router 6	Navigazione SPA client-side
HTTP Client	Axios	Chiamate API con interceptor JWT automatico
i18n	Custom Context	Interfaccia bilingue IT/EN

2.2 Stack Backend

Componente	Tecnologia	Scopo
Framework	FastAPI 0.110	API REST async ad alte prestazioni
Runtime	Uvicorn (ASGI)	Server asincrono production-grade
Validation	Pydantic V2	Type safety e validazione automatica
Database Driver	Motor (async)	Operazioni MongoDB non bloccanti
Auth	python-jose + bcrypt	JWT HS256 + password hashing sicuro
Rate Limiting	SlowAPI	Protezione endpoint da abusi
PDF Export	ReportLab 4.1	Generazione report professionali
LLM	Emergent Integrations	Accesso a OpenAI GPT-5.2

2.3 Infrastruttura

Componente	Tecnologia	Scopo
Database	MongoDB 7.0	Document store flessibile con 15 indici
Container	Docker + Compose	Orchestrazione 3 container (FE, BE, DB)
Proxy	Nginx	Reverse proxy per SPA routing + API forwarding

2.4 Struttura del Progetto

```
backend/  
server.py # Entry point, middleware, lifespan  
models.py # Pydantic models + Enum  
database.py # Motor connection + indexes  
seed.py # Enterprise demo data (14 agents, 20+ policies, 150+ logs, 20 SOX controls)  
exporters.py # PDF/CSV generation (ReportLab)  
routes/ # 9 modular routers (auth, agents, policies, audit, sox_wizard, policy_engine,  
...)   
frontend/src/  
pages/ # DashboardLayout, OverviewPage, AgentsPage, ...  
components/ # CrudPage (generic), Logo, UI components  
locales/ # Traduzioni IT/EN
```

3. Modello Dati

Il database MongoDB ospita 7 collections con 15+ indici ottimizzati per performance su query con filtri, ordinamento e ricerca full-text.

3.x Collection: users

Utenti della piattaforma

Campo	Tipo	Descrizione
id	UUID	Identificativo univoco
username	String (unique)	Nome utente per login
email	String	Email aziendale
password_hash	String	Hash bcrypt della password
role	Enum	admin dpo auditor viewer

3.x Collection: agents

Registro agenti AI

Campo	Tipo	Descrizione
id	UUID	Identificativo univoco
name	String	Nome descrittivo dell'agente
model_type	String	GPT-5.2 Claude-3.5 Custom-ML
risk_level	Enum	low medium high critical
status	Enum	active suspended inactive
allowed_actions	Array	Whitelist azioni consentite
restricted_domains	Array	Blacklist domini ristretti
data_classification	String	public internal confidential restricted

3.x Collection: policies

Regole di governance

Campo	Tipo	Descrizione
id	UUID	Identificativo univoco
name	String	Nome della policy
rule_type	Enum	restriction logging rate_limit approval retention
regulation	Enum	GDPR EU-AI-ACT ISO-27001 ISO-42001 DORA NIS2
severity	Enum	low medium high critical
enforcement	Enum	block log throttle auto

3.x Collection: **audit_logs**

Traccia immutabile azioni AI

Campo	Tipo	Descrizione
id	UUID	Identificativo univoco
timestamp	ISO DateTime	Momento esatto dell'evento
agent_name	String	Agente coinvolto
action	String	Tipo di azione eseguita
outcome	Enum	allowed blocked escalated logged
risk_level	Enum	low medium high critical
policy_applied	String	Policy che ha determinato l'esito

3.x Collection: **compliance_standards**

Standard normativi monitorati

Campo	Tipo	Descrizione
code	String	Codice standard (es. GDPR)
progress	Integer	Percentuale completamento (0-100)
requirements_total	Integer	Requisiti totali
requirements_met	Integer	Requisiti soddisfatti
status	Enum	compliant in_progress non_compliant

3.x Collection: **chat_messages**

Storico conversazioni ARIA

Campo	Tipo	Descrizione
session_id	String	ID sessione conversazionale
role	Enum	user assistant
content	String	Contenuto messaggio (markdown)
timestamp	ISO DateTime	Momento del messaggio

3.x Collection: **sox_controls**

Controlli interni SOX Section 404

Campo	Tipo	Descrizione
domain	String	Access Control Change Mgmt IT Ops Data Integrity Security
control_id	String	Codice controllo (es. AC-01)
status	Enum	not_started in_progress completed failed
evidence	String	Evidenze documentali

Campo	Tipo	Descrizione
risk_level	Enum	low medium high critical

4. Flussi Applicativi

4.1 Flusso di Autenticazione

- **1. Login Request:** Il client invia POST /api/auth/login con username e password.
- **2. Verifica Credenziali:** Il backend cerca l'utente nel DB e verifica l'hash bcrypt.
- **3. Generazione JWT:** Se valido, genera un token JWT (HS256) con payload {sub, role, exp} e scadenza 8 ore.
- **4. Audit Log:** Registra automaticamente un evento 'login' nell'audit trail.
- **5. Client Storage:** Il frontend salva il token in localStorage. L'interceptor Axios aggiunge automaticamente l'header 'Authorization: Bearer {token}' a tutte le richieste.

4.2 Flusso CRUD con Audit Automatico

- **1. Richiesta API:** Il client invia una richiesta (es. POST /api/agents) con il JWT nell'header.
- **2. Validazione JWT:** Il middleware verifica il token e controlla che il ruolo abbia i permessi necessari (RBAC).
- **3. Validazione Dati:** Pydantic V2 valida automaticamente il body della richiesta contro il modello definito.
- **4. Operazione Database:** Motor esegue l'operazione su MongoDB in modo asincrono.
- **5. Audit Automatico:** Ogni operazione CRUD genera un audit_log con dettagli completi (agente, azione, utente, esito).

4.3 Flusso ARIA AI Assistant

- **1. Query Utente:** POST /api/chat con messaggio e session_id. Validazione lunghezza (5-2000 chars).
- **2. Rate Limiting:** SlowAPI verifica il limite di 10 query/minuto per utente.
- **3. Context Loading:** Carica lo storico della conversazione da chat_messages per mantenere il contesto.
- **4. System Prompt:** Prepara il prompt di sistema che definisce ARIA come esperta di compliance EU.
- **5. LLM Call:** Invia la richiesta a GPT-5.2 tramite Emergent Integrations con tutto il contesto.
- **6. Persistenza:** Salva sia il messaggio utente che la risposta in chat_messages. Log audit 'chat_query'.

4.4 Flusso Export PDF

- **1. Richiesta:** GET /api/audit/export/pdf con query params per filtri (outcome, risk_level, search).
- **2. Verifica RBAC:** Solo ruoli admin, dpo e auditor possono esportare.
- **3. Query Filtrata:** MongoDB restituisce i dati filtrati secondo i parametri.
- **4. Generazione PDF:** ReportLab costruisce il documento con header GOVERN.AI, tabella colorata e executive summary.
- **5. Streaming Response:** Il PDF viene inviato come StreamingResponse con Content-Disposition: attachment.

5. Sistema di Sicurezza

5.1 Autenticazione JWT

L'autenticazione utilizza JSON Web Token (JWT) con algoritmo HS256. I token hanno una durata di 8 ore e contengono il nome utente (sub), il ruolo (role) e la scadenza (exp). La chiave segreta è configurata tramite variabile d'ambiente.

5.2 RBAC — Role-Based Access Control

Il sistema implementa 4 ruoli gerarchici. Ogni endpoint verifica che il ruolo dell'utente abbia un livello sufficiente. La gerarchia è: Admin (4) > DPO (3) > Auditor (2) > Viewer (1).

Ruolo	Livello	Read	Write	Delete	Export	Admin
Admin	4	Si	Si	Si	Si	Si
DPO	3	Si	Si	No	Si	No
Auditor	2	Si	No	No	Si	No
Viewer	1	Si	No	No	No	No

5.3 Rate Limiting

Endpoint	Limite	Motivazione
/api/auth/login	5 richieste/min	Prevenzione attacchi brute-force
/api/chat	10 richieste/min	Controllo costi LLM (GPT-5.2)
/api/*/export/pdf	5 richieste/min	Generazione PDF CPU-intensive
/api/*/export/csv	10 richieste/min	File CSV piu leggeri
Altri endpoint	30-60 richieste/min	Uso applicativo normale

5.4 Security Headers

- **X-Content-Type-Options: nosniff** — Previene MIME type sniffing
- **X-Frame-Options: DENY** — Previene clickjacking (iframe)
- **X-XSS-Protection: 1; mode=block** — Filtro XSS del browser
- **Referrer-Policy: strict-origin-when-cross-origin** — Controlla info referer
- **Permissions-Policy: camera=(), microphone=()** — Disabilita API sensibili

6. Moduli Funzionali

6.1 Agent Registry

Scopo: Censimento di tutti gli agenti AI dell'organizzazione

Traccia nome, descrizione, tipo di modello (GPT-5.2, Claude, Custom ML), livello di rischio (low/medium/high/critical), stato operativo (active/suspended/inactive), azioni consentite (whitelist), domini ristretti (blacklist), classificazione dei dati e responsabile.

Use case: Il DPO deve sapere quanti agenti AI ad alto rischio sono in produzione e chi ne è responsabile per la reportistica EU AI Act.

6.2 Policy Engine

Scopo: Definizione di regole di governance per gli agenti

Supporta 5 tipi di regole: restriction (blocca azioni), logging (forza log dettagliato), rate_limit (limita frequenza), approval (richiede approvazione umana), retention (gestisce conservazione dati). Ogni policy è mappata su una normativa europea specifica con 4 livelli di enforcement.

Use case: Creare una policy 'High-Risk AI Oversight' che blocchi decisioni automatiche di credito senza approvazione umana (EU AI Act Art. 14).

6.3 Audit Trail

Scopo: Tracciabilità completa di ogni azione AI

Registra timestamp, agente, azione, risorsa acceduta, esito (allowed/blocked/escalated/logged), livello di rischio, policy applicata, utente e IP. Supporta ricerca full-text, filtri multipli e export in PDF (report branded con Executive Summary) e CSV (UTF-8 BOM per Excel).

Use case: Durante un'ispezione Garante Privacy, esportare tutti gli eventi 'blocked' dell'ultimo trimestre con dettagli delle policy GDPR violate.

6.4 Compliance Dashboard

Scopo: Monitoraggio real-time dello stato di conformità

Monitora 6 standard europei: EU AI Act, GDPR, ISO 27001, ISO 42001, DORA, NIS2. Per ogni standard traccia: percentuale di avanzamento, requisiti soddisfatti/totali, stato (compliant/in_progress/non_compliant), data ultimo assessment e prossima revisione.

Use case: Verificare lo stato di avanzamento GDPR prima dell'audit annuale e identificare i gap da colmare.

6.5 ARIA AI Assistant

Scopo: Consulente AI esperto di compliance EU

Assistente basato su GPT-5.2 con system prompt specializzato in normative europee (AI Act, GDPR, DORA, NIS2, ISO). Mantiene il contesto conversazionale tramite session_id, risponde in italiano e inglese, formatta in Markdown.

Use case: Chiedere ad ARIA come classificare un agente di credit scoring secondo l'EU AI Act e quali requisiti documentali soddisfare.

6.6 Export & Reporting

Scopo: Generazione report professionali

PDF: Report branded con header GOVERN.AI, tabelle colorate per rischio/esito, Executive Summary con statistiche aggregate. CSV: Export con UTF-8 BOM per compatibilit  Excel, supporto filtri. Entrambi protetti da RBAC (solo admin, dpo, auditor).

Use case: Generare un report audit PDF completo per il consiglio di amministrazione di un istituto bancario prima di un'ispezione.

7. Compliance Framework

GOVERN.AI monitora 8 standard normativi europei e internazionali, coprendo l'intero spettro di requisiti per le organizzazioni che utilizzano agenti AI in settori regolamentati (finance, healthcare, PA, energy).

Standard	Tipo	Focus	Sanzioni	Progress Demo
EU AI Act	Regolamento	Classificazione rischio AI	Fino a 35M / 7%	45%
GDPR	Regolamento	Protezione dati personali	Fino a 20M / 4%	78%
ISO 27001	Standard	Sicurezza delle informazioni	Perdita certificazione	92%
ISO 42001	Standard	Gestione sistemi AI	Perdita certificazione	35%
DORA	Regolamento	Resilienza digitale finanza	Sanzioni settoriali	61%
NIS2	Direttiva	Cybersecurity infrastrutture	Fino a 10M / 2%	83%
SOX	Regolamento	Controlli interni finanziari	Sanzioni penali/civili	56%
D.Lgs. 262	Legge IT	Controlli contabili quotate	Sanzioni CONSOB	48%

I valori di progress si riferiscono allo scenario demo enterprise (Banca Enterprise S.p.A.) e rappresentano un esempio realistico di stato di conformita per un istituto bancario italiano.

8. Deployment & DevOps

L'intero stack applicativo è containerizzato con Docker e orchestrato tramite Docker Compose. Il setup completo richiede 3 comandi.

8.1 Architettura Container

Container	Immagine Base	Porta	Funzione
MongoDB	mongo:7	27017	Database con volume persistente
Backend	python:3.11-slim	8001	FastAPI + Uvicorn + auto-seed
Frontend	node:18 + nginx:alpine	3000	React build + Nginx reverse proxy

8.2 Setup Rapido

```
git clone https://github.com/.../GOVERN.AI && cd GOVERN.AI
cp .env.example backend/.env # Configurare JWT_SECRET_KEY e LLM key
docker-compose up --build # Avvia tutti i servizi
# Accessibile su http://localhost:3000
# Credenziali demo: admin / AdminGovern2026!
```

9. Roadmap Prodotto

Completato (MVP v3.0)

- Core platform completa (Agent Registry, Policy Engine, Audit Trail, Compliance Monitor)
- Autenticazione JWT con RBAC a 4 livelli
- ARIA AI Assistant con SSE streaming, contestualizzato su score e conflitti
- Export report in PDF e CSV (Audit, Compliance, SOX)
- Dashboard con grafici interattivi (Recharts)
- 8 standard normativi (EU AI Act, GDPR, ISO 27001/42001, DORA, NIS2, SOX, D.Lgs. 262)
- SOX Section 404 Wizard con 20 controlli e Audit Readiness Score
- Policy Conflict Detection Engine (4 tipi di conflitto)
- **Step E5 — Policy Guidance Engine:** guidance contestuale + impact analysis + note di risoluzione obbligatorie + audit log
- **Step E6 — Compliance Intelligence Engine:** scoring deterministico (0-100) di agenti, standard e governance complessiva
- **Intelligence Center:** dashboard premium investor-ready con score ring, ranking, insights, remediation
- Service layer disaccoppiato (services/compliance_engine.py)
- CI/CD GitHub Actions (4 job) + 50/50 test backend passanti
- Docker deployment (Compose) + Interfaccia mobile responsive

Prossimi Sviluppi

- **D.Lgs. 262 Wizard:** Workflow dedicato per attestazione dirigente preposto
- **Auto-Fix Engine:** Risoluzione automatica dei conflitti tra policy
- **Test Frontend:** Test unitari con Jest e Testing Library

Vision Enterprise (P2)

- **Multi-tenancy:** Supporto clienti multipli con isolamento dati
- **Connettori Enterprise:** Integrazione con SIEM (Splunk, ELK), IAM (Okta, Azure AD), ServiceNow
- **WebSocket Real-time:** Monitoraggio live con aggiornamenti push
- **API Key Management:** Registrazione agenti via API esterna
- **Sistema Notifiche:** Email alerts su violazioni policy critiche

10. Target Audience & Value Proposition

DPO / Compliance Manager

- Visibilità totale sugli agenti AI in produzione
- Tracciabilità di ogni azione per audit e ispezioni
- Mapping normativo automatico (GDPR, AI Act, DORA)
- Report pronti per regolatori in formato PDF

CISO

- Classificazione rischio allineata a EU AI Act
- Policy enforcement automatico con 4 livelli
- Security headers e rate limiting integrati
- RBAC granulare con 4 livelli di permessi

CTO / Engineering

- API REST documentata (Swagger/ReDoc automatico)
- Architettura modulare e manutenibile
- Stack moderno (FastAPI, React, MongoDB)
- Docker ready per deployment rapido

CEO / Board

- Riduzione rischio sanzioni (AI Act: fino a 35M)
- Due diligence documentabile per investitori
- Competitive advantage sulla compliance
- Dashboard executive con KPI real-time

GOVERN.AI

Sovereign Control Plane for Enterprise AI

powered by ANTHERA Systems

Angelo Anglani — Founder & Lead Engineer

angelo.anglani94@gmail.com | +39 342 754 8655

linkedin.com/in/angelo-anglani

Documento generato: May 2026 — Versione 2.4